

보안 위협 모델과 데이터 정책을 P0 Gate로 확정

Issue #39 설계·정책 코드화·자동 검증 완료 보고서

완료 판정	18개 위협과 28개 통제를 연결하고, 잔여 위험을 모두 Medium 이하로 제한했습니다. 데이터 4등급과 보존 규칙 18개를 기계 검증 가능한 정책으로 고정했습니다.
-------	---

18	28	4	18	12/12
Threats	Controls	Data Classes	Retention Rules	Policy Tests

대상	결과
상위 Epic	#3 P0 제품 기반 확정
추적 Issue	#39 보안 위협 모델 및 데이터 정책
구현 영향	문서·정책·검증기만 변경, 서버·Flow·Secret 변경 없음
최종 상태	#39 완료 후 Epic #3는 제품 책임자 승인 대기

문서 상태 완료

검증 기준일 2026-08-01

1. 완료 범위와 제품 경계

이번 작업은 P0 기반에서 누락되어 있던 보안 위협 모델과 데이터 분류·보존 정책을 제품 계약으로 확정한 것입니다. 기존 ADR-0001~0005의 책임, Secret, 백업, 관측성, 이미지 잠금 결정을 변경하지 않고 상위 보안·데이터 생명주기 Gate를 추가했습니다.

책임 경계

구성요소	소유 책임	금지 또는 제한
TechFlow Core	정책·권한·상태·역등성·감사	Flow에 정책 결정을 위임하지 않음
Activepieces	시각적 실행·연결·Run 이력	인프라 권한·정책 상태 소유 금지
Gateway / Adapter	입력 검증·정규화·제한된 Egress	원문·Secret 영속 저장 금지
AI/RAG Gateway	수집 Gate·ACL·출처·보류	D2·D3 및 Tool 실행 금지
ABLESTACK API	최종 권한·자원 상태·명령 실행	AI 출력 직접 실행 금지

Fail Closed

정책 판정, 분류, 권한, 출처 또는 삭제 상태가 불명확하면 수집·전송·실행을 중단합니다.

보호 자산

- 사용자·운영자 ID와 세션, Webhook·API Secret, 승인된 Flow 버전
- 실행·감사·관측 메타데이터와 PostgreSQL·Redis·백업
- 지식 Source·Chunk·Embedding, AI Prompt·응답·평가 데이터
- ABLESTACK 자원·명령, 이미지·Piece·모델 공급망

2. 위협 모델

자산 9개, 신뢰 경계 11개, 공격 시나리오 18개, 통제 28개를 ID로 연결했습니다. 가능성과 영향을 각각 1~5로 평가해 곱한 값을 고유 위험으로 사용하고, 통제 후 잔여 위험은 9 이하만 허용합니다.

위험 점수	등급	처리 원칙
1-4	Low	기본 통제와 정기 검토
5-9	Medium	담당자·검증 방법 지정
10-15	High	구현 전 통제·테스트·승인
16-25	Critical	통제 전 배포·수집 금지

18개 위협 군

구간	주요 위협	핵심 통제
T01-T04	Webhook 위조·재전송·Injection-SSRF	HMAC-TLS-Allowlist-Dedup-Strict Egress
T05-T10	Secret·권한·공급망·Flow 우회·로그·백업	보호 저장소·최소 권한·Digest·감사·분리
T11-T14	Prompt Injection·지식 오염·교차 등급 유출·환각	Source 검역·ACL 선적용·출처·보류
T15-T18	과도한 자율성·비용 고갈·Provider 보존·불완전 삭제	Tool 금지·제한·계약·Lineage·삭제 SLO

제품 Gate

잔여 위험이 High 이상이면 Issue를 완료하지 않습니다. 통제가 준비되지 않은 기능은 비활성화하거나 데이터 범위를 축소합니다.

3. 상위 위험과 통제 결과

위험	고유	주요 통제	잔여
교차 등급-Tenant 검색 유출	25	검색 전 ACL, D2-D3 차단, 격리 테스트	6
AI의 과도한 자율 실행	25	Tool 실행 금지, Human Approval, API 재검증	5
Prompt Injection	20	문서는 데이터로 처리, 출처·보류, Tool 차단	6
Secret-세션 노출	20	보호 저장소, 런타임 주입, 로그·저장소 검사	5
SSRF-과도한 Egress	20	고정 목적지 Allowlist, Strict Network	5
Provider 입력 보존·학습	20	처리 계약, D2-D3 전송 금지, Provider 추상화	5
백업·복구본 노출	20	Secret 분리, 권한, Checksum, 격리 복구	5

신뢰 경계

경계	검증
External → Ingress	HTTPS-서명·이벤트 Allowlist
Gateway → Activepieces	최소 이벤트 계약·Delivery ID
Activepieces → External	Adapter·고정 URL·Timeout·결과 검증
Source → RAG	Source Allowlist·Owner·Version·Hash·검역
RAG → Provider	등급 Gate·처리 계약·최소 Prompt
Human → Core → ABLESTACK	승인·최소 권한·먹등성·사후 상태 확인

참조 프레임워크는 NIST AI RMF, NIST AI RMF Generative AI Profile, OWASP Top 10 for LLM Applications 2025, GitHub Webhook 보안 권장사항입니다.

4. 데이터 분류 정책

데이터는 생성·수집 시점에 등급, 소유자, 목적, 보존 정책과 파생 관계를 부여합니다. 등급이 불명확하거나 여러 등급이 섞이면 가장 높은 등급을 적용합니다. Embedding은 원문과 같은 등급입니다.

등급	정의와 예	기본 처리	P1 RAG
D0 Public	공개 문서·공개 저장소·공개 Issue	출처·버전·Hash 유지	허용
D1 Internal	운영 이벤트·승인 내부 문서	인증 사용자·목적 제한	조건부
D2 Confidential	고객·개인·지원 원문	명시 승인·암호화·최소 보존	금지
D3 Restricted	비밀번호·Token·Secret·인증 Header	일반 DB·로그·RAG·Issue 저장 금지	금지

필수 메타데이터

식별·분류	출처·버전	수명주기	권한·추적
dataId, classification, owner, purpose	sourceId, sourceVersion, sourceUri, parentDataIds	createdAt, expiresAt, retentionPolicyId, deletionState	tenantId, accessScope, correlationId, legalHoldId

최소 수집	로그·메트릭에는 Payload가 아니라 상태, 개수, 시간, 허용된 오류 코드와 상관관계 ID만 기록합니다.
-------	--

5. 보존·삭제 정책

정책	데이터	최대 보존	핵심 조건
R01	원문 Webhook·인증 Header	0일	메모리 검증 후 즉시 폐기
R02–R06	정규화 Event·Run·로그·Observer·감사	30–365일	원문 금지·회전·감사
R07	정기 상태 백업	7일	ADR-0003
R08	복구 연습 백업	30일	격리 후 즉시 제거
R09	Secret Escrow	교체 검증 후 30일 이내	일반 백업 제외
R10–R12	공개·내부 지식 Source·Embedding	수명 / 365일	출처·재승인·파생 삭제
R13	AI Prompt·응답 원문	기본 미수집 / opt-in 30일	D2·익명화 또는 삭제
R14–R16	익명 평가·지원·사용량	180–365일	원문 연결 제거
R17	고객 원문 Export	P1 수집 금지	향후 R2 별도 승인
R18	Secret·Token·API Key	0일	보호 저장소만 허용

삭제 수명주기

상태	처리
ACTIVE → EXPIRING	검색·신규 Flow 입력에서 제외
DELETION_REQUESTED	Source ID로 Chunk·Embedding·Cache·평가 연결 추적
DELETED	Primary·Index에서 7일 이내 제거, 건수·시각만 감사 기록
BACKUP REPLAY	복구 직후 삭제 Ledger 재적용, 만료 시 자연 폐기

삭제 SLO

Source 철회 후 Source·Chunk·Embedding·Cache·평가 연결을 최대 7일 안에 삭제합니다.

6. AI/RAG P1 구현 Gate

Issue #20은 아래 Gate가 구현·검증되기 전 실제 데이터를 수집하지 않습니다. 자동 만료·파생 삭제가 준비될 때까지 D0 공개 문서만 PoC 범위로 제한합니다.

Gate	완료 조건
Source Registry	등급·Owner·제품·Version·Hash·보존 정책 저장
Quarantine	Secret·개인정보·악성 지시·출처 위조 검사 후 승인
ACL Before Search	Vector 검색 전에 Tenant·사용자·등급 조건 적용
Data, not Instruction	검색 문서는 지시가 아니라 데이터로 취급
Grounded Answer	Source·Version 제시, 근거 부족·충돌 시 답변 보류
No Agency	AI 출력의 Shell·API·Activepieces·ABLESTACK 직접 실행 금지
Provider Contract	학습·장기 보존 비활성, D2·D3 전송 차단
Deletion Propagation	Source 철회가 Chunk·Embedding·Cache·평가까지 전파

등급별 P1 허용

등급	수집	Embedding	Prompt 전송
D0	허용	허용	허용
D1	승인 시	승인 시	승인 Provider만
D2	금지	금지	금지
D3	금지	금지	금지

출력 안전	AI 답변은 근거를 제공하거나 보류하며, 자원 변경은 별도 승인·권한·먹등성 계약을 통과한 TechFlow Core만 수행합니다.
-------	--

7. 운영·예외·장애 처리

운영 Runbook은 신규 데이터 등록, Provider 승인, 삭제 요청, 보존 검토, Legal Hold, 보안 사고, 롤백의 순서를 표준화합니다.

절차	핵심 단계	증적
분류 Intake	Owner-목적-등급-보존-파생 관계 결정	정책 ID-승인자
RAG Source	Registry → Quarantine → Scan → Approval → Publish	Hash-Version-ACL
Provider	처리 계약-지역-보존-학습-삭제 확인	승인 기록
삭제	검색 제외 → Lineage 추적 → 7일 이내 삭제 → 재검증	Deletion Ledger
사고	탐지 → 분류 → 격리 → 자격증명 교체 → 삭제 → 복구	Threat ID-조치
롤백	Source-Flow-Provider 비활성 → 직전 정책 복원 → 재검증	Validator PASS

Legal Hold

- 제품 책임자와 보안 책임자의 이중 승인, 근거·대상·등급·기간·요청자를 기록합니다.
- 다음 검토일은 90일 이내이며, Hold는 접근통제·암호화·공개 금지를 해제하지 않습니다.
- Hold 종료 시 원래 만료일이 지난 데이터는 즉시 삭제 절차로 이동합니다.

예외 원칙	고객 공개 여부와 제품화 여부는 별도 제품 결정입니다. 구현 단계의 보안 Gate는 공개 여부와 관계없이 동일하게 적용합니다.
-------	--

정기 검토

주기	검토
매월	만료·삭제 지연·미분류 데이터·Provider 설정
분기	D1 재승인·권한·복구 시 삭제 Ledger 재적용
변경 시	새 Connector·Provider·Domain Pack·ABLESTACK 명령 경계

8. 검증 결과와 Epic #3 종료 준비

ID	검증	결과
V01-V03	JSON 형식, ID 고유성, 모든 참조 유효	PASS
V04	모든 잔여 위험 9 이하	PASS
V05-V06	D0-D3 정확성, D3 기본 수집 금지	PASS
V07	원문 Webhook-Secret 보존 0일	PASS
V08	AI 원문 opt-in-최대 30일	PASS
V09	D2-D3 P1 RAG 차단	PASS
V10	파생 데이터 삭제 SLO 최대 7일	PASS
V11	Legal Hold 이중 승인-90일 검토	PASS
V12	단위 테스트 12건	PASS

Issue #39	ADR 2건, 구조화 정책 JSON, Validator, 12개 단위 테스트, Runbook, Markdown/PDF 보고서, PPTX/PDF 발표자료를 완료했습니다.
-----------	---

제품 책임자 승인 항목

- 잔여 위험 허용 상한: Medium(9 이하)
- 데이터 등급: D0 Public, D1 Internal, D2 Confidential, D3 Restricted
- 보존 기준: 원문 Webhook-Secret 0일, 로그 30일, 감사 365일, 백업 7/30일
- P1 RAG: D0 기본, D1 조건부, D2-D3 금지, Tool 실행 금지
- 삭제 SLO: Source-Chunk-Embedding-Cache-평가 연결 최대 7일
- Legal Hold: 제품·보안 이중 승인과 90일 이내 재검토

Epic #3	#39 병합·종료 후 모든 하위 Issue가 완료됩니다. Epic #3와 M0 Milestone은 제품 책임자의 최종 승인 후 닫습니다.
---------	--

후속: #20 D0 RAG PoC → #23 보존 위반 KPI → #24 삭제 Job 실패 재처리·알림